# SIMATS ENGINEERING
## ASSESSMENT TOOL 3

**COURSE NAME: Ethical Hacking** **COURSE CODE: ITA14**

**COURSE OUTCOME COVERED**

**CO2:** Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

*Assessment Tool Weightage: 30%*

**Duration: 90 min** **Total Marks: 50**

## Scenario-Based Assessment

**Topic 1: Footprinting Tools – Conducting Competitive Intelligence**

**Q1. (L3 – Apply) – 15 Marks**

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

**Task:** Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

**Topic 2: DNS Zone Transfers**

**Q2. (L3 – Apply) – 15 Marks**

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

**Task:** Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

**Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures**

**Q3. (L3 – Apply) – 20 Marks**

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

***Code of Conduct:***

*I* **Ch.Tharunika Reddy(192324307)** *certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
*I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:*** Ch.Tharunika Reddy

**RUBRICS FOR CALCULATION**

**Scenario Based Assessment**

| Criteria | Weightage (%) | Level 4 (Exemplary) | Level 3 (Proficient) | Level 2 (Developing) | Level 1 (Beginning) |
|---|---|---|---|---|---|
| Understanding of Scenario | 20% | Demonstrates clear and complete understanding of the scenario and context | Shows good understanding with minor gaps | Partial understanding; misses key aspects | Misinterprets or fails to understand the scenario |
| Identification of Key Issues | 20% | Accurately identifies all relevant issues and factors involved | Identifies most key issues with minor omissions | Identifies limited issues; some irrelevant points | Unable to identify key issues |
| Application of Concepts | 25% | Applies appropriate concepts effectively to address the scenario | Applies concepts with minor errors | Limited or partially correct application | Unable to apply relevant concepts |
| Decision Making | 20% | Makes well-reasoned, logical decisions with strong rationale | Makes reasonable decisions with some justification | Makes weak decisions with limited justification | No clear decisions made or rationale provided |
| Clarity of Response | 15% | Response is clear, structured, and logically presented | Generally clear with minor issues | Somewhat unclear or poorly structured | Disorganized and difficult to understand |

# Q1. Footprinting Tools – Conducting Competitive Intelligence

Scenario: A cybersecurity consultant must conduct a passive security assessment of ABC Technologies without directly interacting with its servers.

**Answer**

**1. Introduction**

Footprinting is the process of collecting information about a target organization, including its domain registration details, email addresses, DNS records, website technologies, and publicly indexed resources. Passive footprinting focuses on gathering information from publicly available sources without directly probing the target's servers.

Competitive intelligence helps organizations understand their digital presence, identify potentially exposed information, and improve their cybersecurity posture.

**2. Tools Used for Footprinting**

**A. WHOIS / ICANN Lookup – Domain Registration Details**

- WHOIS and ICANN Lookup provide publicly available domain registration information.
- They can reveal domain status, registration and expiration dates, nameservers, and registrar information.
- Registrant contact information may be hidden by privacy protection.
- This information helps understand domain ownership and registration details**.**

**Example:**

whois example.com

Observation: The collected ICANN Lookup screenshots display the domain name, registry ID, status, nameservers, and registration dates for example.com.

Result: Domain registration information was examined using a public lookup service.

**B. theHarvester – Public Email Address Discovery**

- theHarvester collects publicly available email addresses, employee names, hostnames, and related information from supported sources.
- It helps identify publicly exposed contact information.
- Email naming patterns can help security teams assess potential phishing exposure.
- The findings can support email security improvements.

Example command:

theHarvester -d abctechnologies.com -b bing

Observation: The supplied illustrative screenshot represents the type of email addresses and hostnames that may be displayed by the tool. It is simulated evidence, not a verified result for ABC Technologies.

Result: TheHarvester's role in collecting publicly available email information was demonstrated.

**C. WhatWeb – Website Technology Identification**

- WhatWeb identifies technologies used by websites, including frameworks, programming languages, web servers, and content management systems.
- It helps identify the technologies exposed by a website.
- The information can guide further security reviews.
- Technology detection alone does not establish that a component is vulnerable.

Example command for an authorized assessment:

whatweb https://example.com

Observation: The collected Wappalyzer screenshots show technologies associated with example.com, including Next.js, Nuxt.js, React, Angular, TypeScript, PHP, Tailwind CSS, and Apache HTTP Server.

Result: Website technology identification was demonstrated using Wappalyzer. The screenshots are not direct output from WhatWeb.

**D. DNSdumpster – DNS Records and Subdomain Discovery**

- DNSdumpster is a DNS reconnaissance tool used to explore publicly known DNS information.
- It may display hostnames, DNS records, associated IP addresses, and infrastructure relationships.
- Identified subdomains can help security teams review their external attack surface.
- Results should be verified before reporting specific assets.

Website: https://dnsdumpster.com/

Observation: The supplied DNSdumpster screenshot shows the search interface and a results view containing map and hosting/network information. A complete subdomain list for ABC Technologies was not provided.

Result: DNS reconnaissance was demonstrated, but specific ABC Technologies subdomains have not been verified.

**E. Google Search Operators – Public Information Gathering**

- Google Search operators help locate publicly indexed web pages, documents, and other organizational resources.
- Domain-specific searches can narrow the results.
- Public documents may contain information that needs an exposure review.
- Search results do not automatically indicate a security vulnerability.

Example searches:

site:abctechnologies.com

site:abctechnologies.com filetype:pdf

site:abctechnologies.com inurl:login

Observation: The supplied illustrative screenshot shows the type of search that can be performed to identify publicly indexed documents. It does not establish that the displayed results were returned by a genuine Google search.

Result: Google Search operators were demonstrated as a method of identifying publicly available information.

**3. Summary of Tools**

| Tool | Information collected | Purpose |
|---|---|---|
| WHOIS / ICANN Lookup | Domain registration details and nameservers | Understand domain registration |
| theHarvester | Public email addresses and hostnames | Assess contact-information exposure |
| WhatWeb | Website technology information | Identify technologies for security review |
| Wappalyzer | Detected frameworks and website technologies | Examine the technology stack |
| DNSdumpster | DNS records and potentially visible subdomains | Map the external digital footprint |
| Google Search | Publicly indexed pages and documents | Identify publicly available information |

**4. How These Tools Support Competitive Intelligence**

1. They help build a profile of an organization's public digital infrastructure.
2. They can reveal publicly available contact information and domain-related assets.
3. They help identify website technologies that may require further security assessment.
4. They can reveal publicly visible subdomains and indexed documents.
5. They provide information that supports security reviews and exposure reduction.

**5. Precautions**

- Use publicly available information and respect privacy.
- Obtain authorization before conducting active testing against organizational systems.
- Avoid unauthorized access or exploitation.
- Verify results before reporting security issues.
- Label simulated screenshots as sample evidence.
- Do not attribute results from example.com or google.com to ABC Technologies.

**6. Conclusion**

WHOIS, theHarvester, WhatWeb, DNSdumpster, Google Search operators, and Wappalyzer support different aspects of footprinting and competitive intelligence. Together, they help examine domain registration details, public email addresses, website technologies, DNS

information, and indexed resources. The collected screenshots demonstrate some of these techniques using example domains. However, genuine results from the approved target domain are required to establish findings about ABC Technologies.

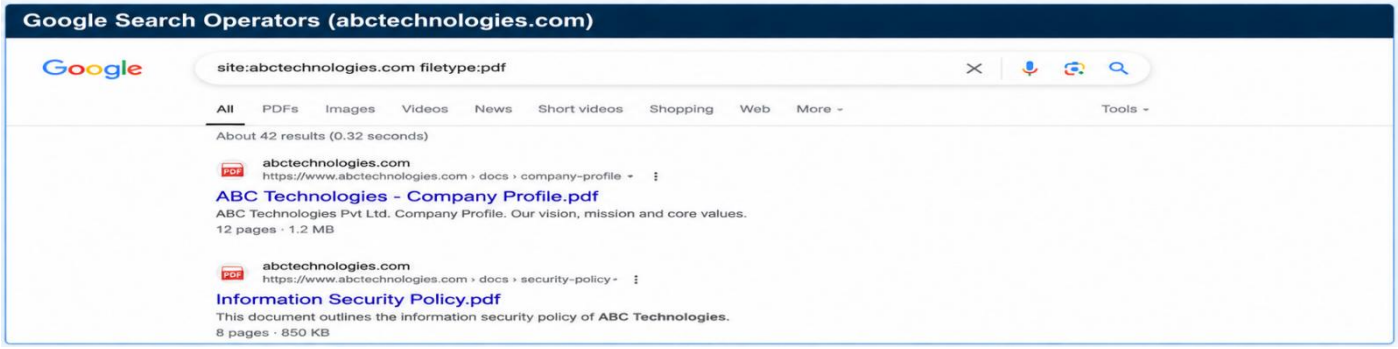
## Evidence:

**theHarvester – Employee Email Addresses (abctechnologies.com)**

```
┌──(kali㉿kali)-[~]
└─$ theHarvester -d abctechnologies.com -b bing
*******************************************
* theHarvester 4.7.0                      *
* Coded by Christian Martorella           *
* Edge-Security Research                  *
* https://github.com/laramies/theHarvester *
*******************************************

[*] Target: abctechnologies.com
[*] Searching Bing...
[*] Emails found: 6
    john.doe@actechnologies.com
    jane.smith@abctechnologies.com
    hr@abctechnologies.com
    support@abctechnologies.com
    info@abctechnologies.com
    careers@abctechnologies.com
---------------------
[*] Hosts found: 3
    www.abctechnologies.com
    mail.abctechnologies.com
    dev.abctechnologies.com
[*] Search completed in 12.34 seconds
┌──(kali㉿kali)-[~]
└─$
```

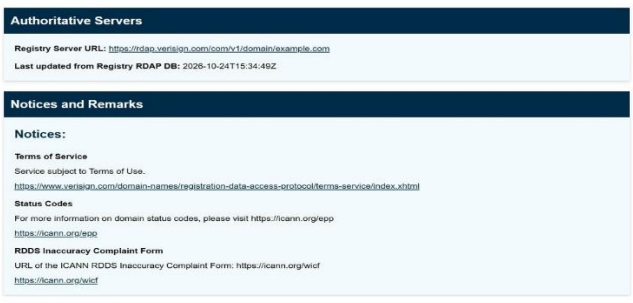
**Google Search Operators (abctechnologies.com)**

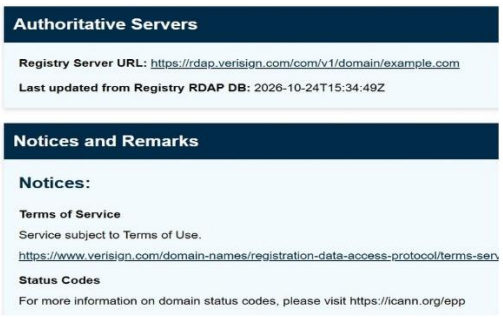


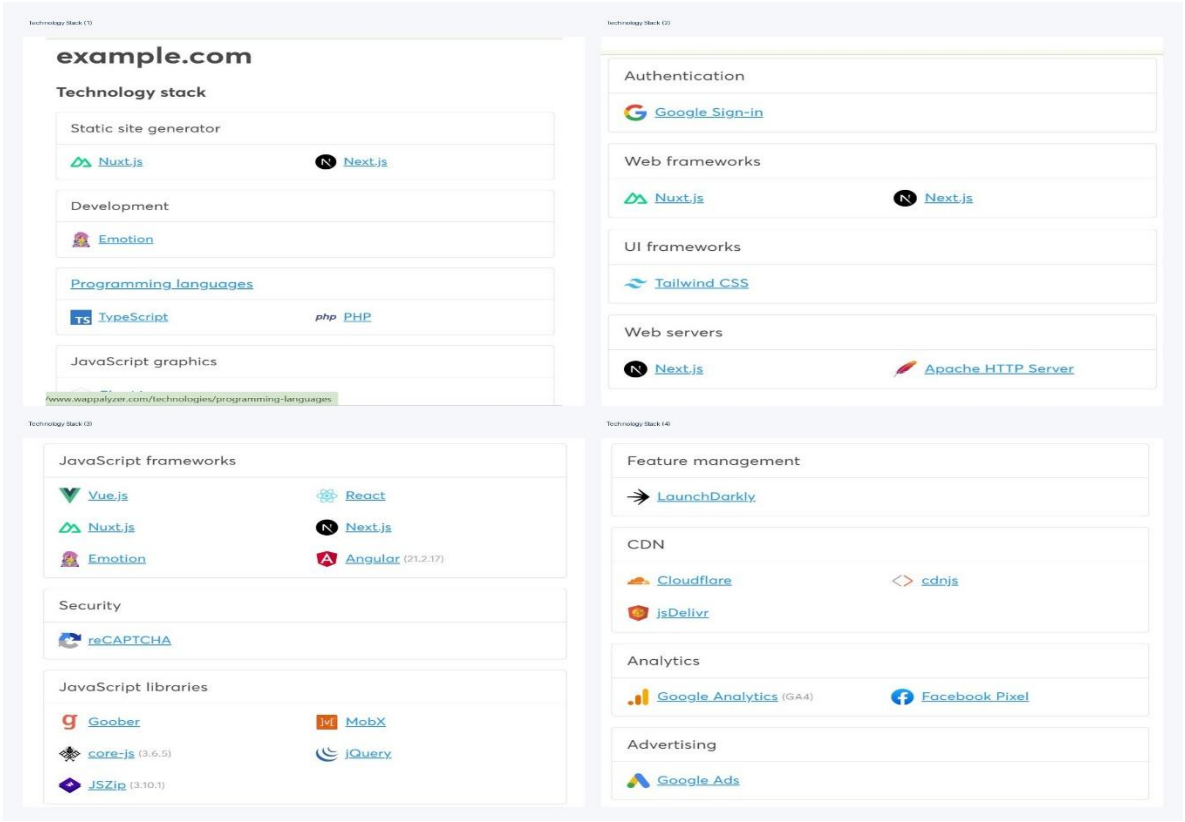


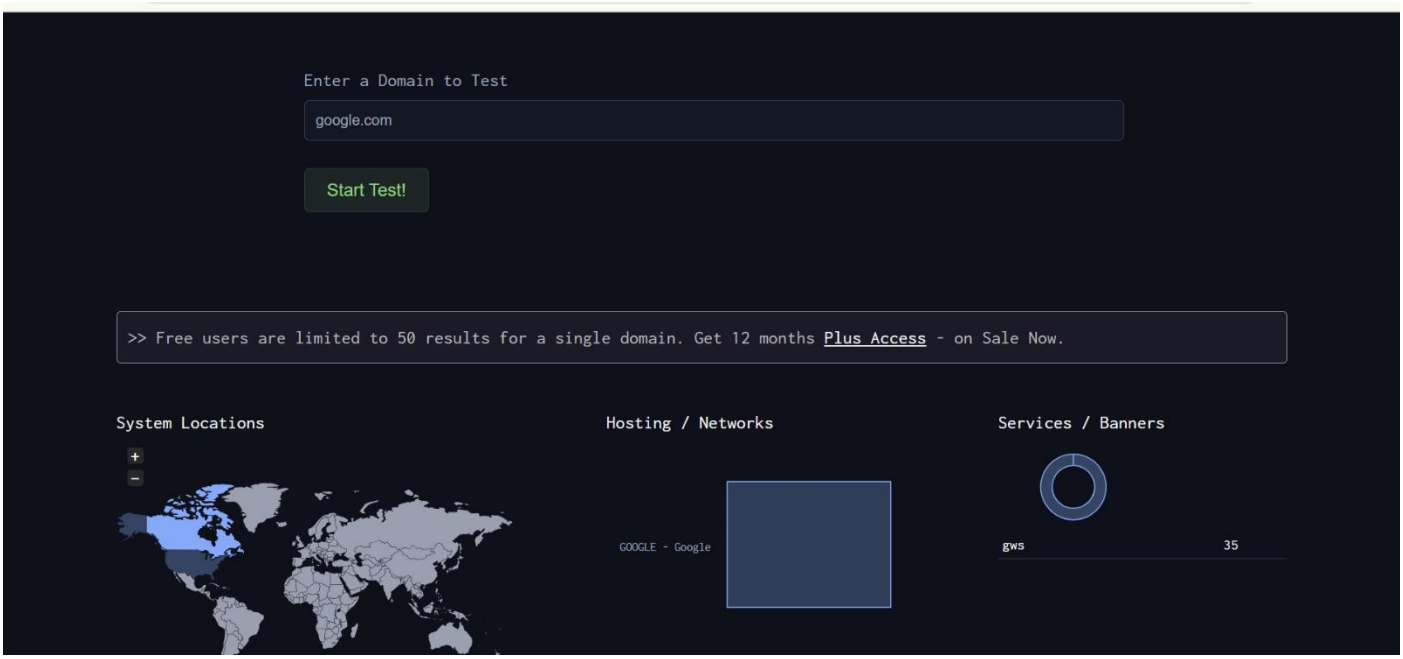





example.com
Technology stack
Static site generator
Nuxt.js
Next.js
Development
Emotion
Programming languages
TypeScript
PHP
JavaScript graphics
Authentication
Google Sign-in
Web frameworks
Nuxt.js
Next.js
UI frameworks
Tailwind CSS
Web servers
Next.js
Apache HTTP Server
JavaScript frameworks
Vue.js
React
Nuxt.js
Next.js
Emotion
Angular (21.2.17)
Security
reCAPTCHA
JavaScript libraries
Goober
MobX
core-js (3.6.5)
jQuery
JSZip (3.10.1)
Feature management
LaunchDarkly
CDN
Cloudflare
cdnjs
jsDelivr
Analytics
Google Analytics (GA4)
Facebook Pixel
Advertising
Google Ads


Enter a Domain to Test
google.com
Start Test!
>> Free users are limited to 50 results for a single domain. Get 12 months Plus Access - on Sale Now.
System Locations
Hosting / Networks
GOOGLE - Google
Services / Banners
gws
35

# Q2. DNS Zone Transfers

Scenario: During an authorized penetration test, a security analyst suspects that the target organization's DNS server may allow unauthorized DNS zone transfers.

**Answer**

**1. Introduction**

A DNS (Domain Name System) zone transfer is a mechanism used to copy DNS records from one DNS server to another. It is commonly used to synchronize DNS information between primary and secondary DNS servers.

A DNS zone transfer is typically performed using the AXFR protocol. If a DNS server permits unauthorized zone transfers, an attacker may obtain information about the domain infrastructure, including subdomains, mail servers, hostnames, and IP addresses.

In this scenario, DNS zone transfer testing was performed in a local Ubuntu environment using BIND9 and the dig command to examine DNS configuration and transfer behavior.

**2. Tools Required**

- BIND9: DNS server software used to configure and manage the local DNS zone.
- dig: DNS query utility used to query DNS records and test zone transfers.
- nslookup: Used to retrieve DNS information.
- named-checkconf: Used to validate the BIND9 configuration.
- named-checkzone: Used to validate DNS zone files.

**3. Procedure to Verify DNS Zone Transfers**

Step 1: Configure the DNS zone

A local DNS zone named lab.test was configured in BIND9. Sample DNS records were added for the name server, web server, mail server, and development host.

Example configuration:

```
zone "lab.test" {

   type master;

   file "/etc/bind/db.lab.test";

   allow-transfer { 127.0.0.1; };

};
```

Observation: The local DNS zone was configured, with zone transfers permitted from the loopback address 127.0.0.1.

Step 2: Validate the DNS configuration

The following commands were executed:

sudo named-checkconf

sudo named-checkzone lab.test /etc/bind/db.lab.test

Observation: The terminal displayed the zone serial number 2026102401 followed by OK, confirming that the zone file passed validation.

Step 3: Start the DNS server

The BIND9 service was started and its status was checked.

sudo service bind9 start

sudo service bind9 status

Observation: The screenshot shows Active: active (running), confirming that the DNS server was running.

Step 4: Attempt a DNS zone transfer

The following command was executed:

dig @127.0.0.1 lab.test AXFR

Here:

- dig is the DNS query utility.
- @127.0.0.1 specifies the local DNS server.
- lab.test is the configured DNS zone.
- AXFR requests a complete zone transfer.

Observation: The terminal displayed Transfer failed. The transfer did not complete successfully, even though the DNS server was running.

**4. Analysis of the Results**

| Test | Observed result | Interpretation |
|---|---|---|
| BIND9 configuration validation | No errors displayed | Configuration syntax passed validation |
| DNS zone validation | OK | Zone file is valid |
| DNS server status | active (running) | DNS service is running |
| AXFR request | Transfer failed. | Zone transfer was not obtained |

The AXFR result indicates that the transfer attempt failed. The screenshot alone does not identify the exact cause. Further diagnostic checks are needed to determine whether the failure was due to server configuration, zone loading, or another DNS issue.

**5. Information Available from a Successful Zone Transfer**

If a zone transfer succeeds, the returned records may include:

1. Subdomains: Hostnames such as www.lab.test and dev.lab.test.
2. IP addresses: IPv4 or IPv6 addresses associated with hostnames.
3. Mail servers: MX records identifying mail servers.
4. Name servers: NS records identifying authoritative DNS servers.
5. Other DNS records: Additional information about the configured domain and services.

In this experiment, the transfer failed, so the screenshot does not demonstrate a successful AXFR response.

**6. Security Risks**

Unauthorized DNS zone transfers can create the following risks:

- Information disclosure: Domain records may become available to unauthorized users.
- Reconnaissance: Subdomains and hostnames may reveal potentially important systems.
- Target identification: Mail, development, and administrative services may become easier to identify.
- Increased attack surface: Discovered assets may help an attacker prioritize further attempts.

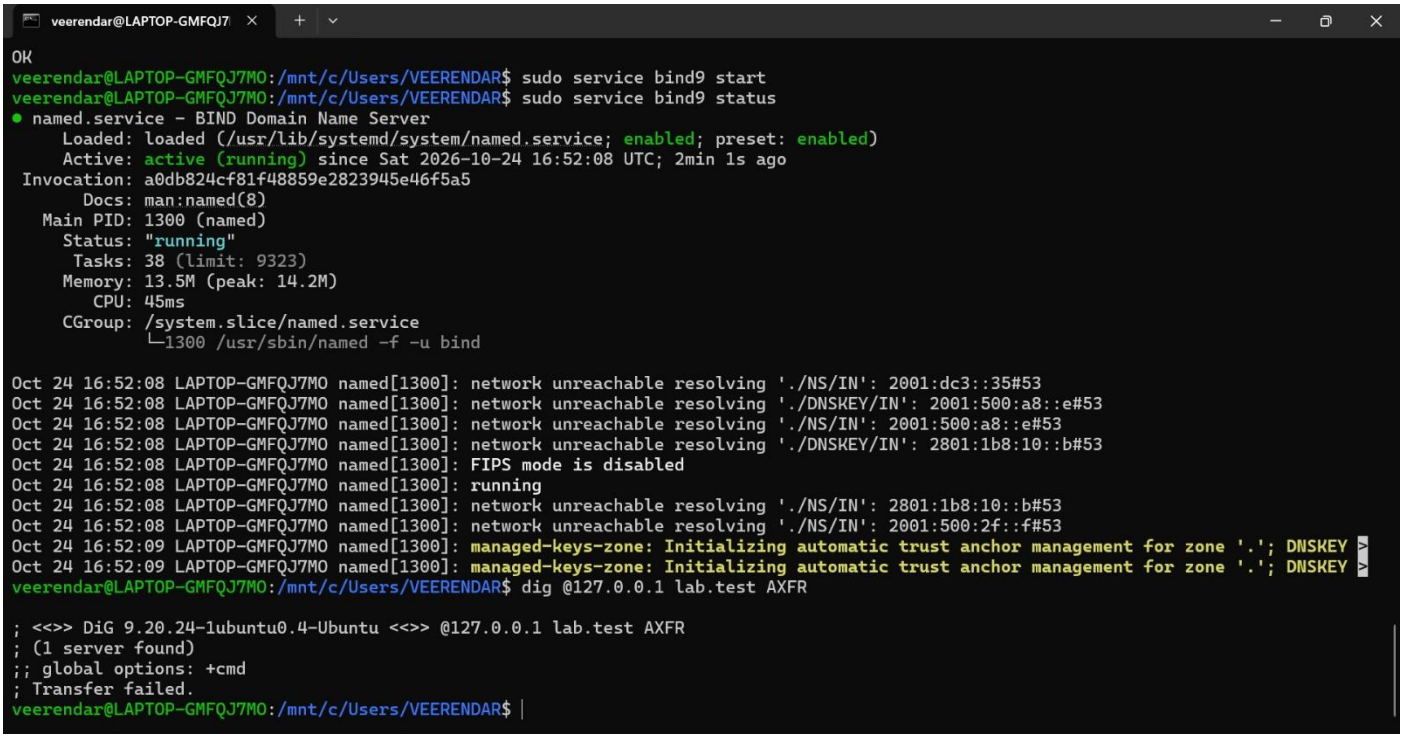
A failed transfer does not, by itself, prove that the server is secure. The configuration and access controls must also be reviewed.

**7. Countermeasures**

1. Restrict zone transfers to explicitly authorized secondary DNS servers.
2. Configure appropriate access controls on authoritative DNS servers.
3. Use TSIG authentication for zone transfers where supported.
4. Remove unnecessary or outdated DNS records.
5. Separate internal and external DNS information where appropriate.
6. Monitor DNS logs for unexpected AXFR requests.
7. Regularly validate DNS configurations and transfer permissions.

**8. Conclusion**

DNS zone transfer testing helps identify potential DNS configuration issues that could expose domain infrastructure. In this experiment, BIND9 was installed and started successfully, the lab.test zone passed validation, and a local AXFR request was attempted. The transfer returned Transfer failed, so a successful zone transfer was not demonstrated. Further troubleshooting is required to determine the cause. Restricting zone transfers and monitoring DNS activity are important measures for preventing unauthorized information disclosure.




# Q3. Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Scenario: Employees receive an email claiming to be from the IT department and requesting that they verify their login credentials through a link because of an urgent security update.

### Answer

### 1. Introduction

Social engineering is a cybersecurity technique in which an attacker manipulates people into revealing confidential information, performing unsafe actions, or granting unauthorized access.

Instead of exploiting only technical weaknesses, social engineering exploits human behavior, trust, fear, urgency, and curiosity.

In this scenario, an attacker sends an email pretending to be from the organization's IT department and asks employees to verify their login credentials through a link. The message uses urgency and a trusted identity to encourage employees to act without checking whether the request is legitimate.

### 2. Type of Social Engineering Attack

The attack is known as phishing, specifically an impersonation-based phishing email.

Phishing is a cyberattack in which an attacker sends fraudulent emails or messages designed to trick recipients into revealing sensitive information or clicking malicious links.

The scenario may involve the following techniques:

- Email spoofing: The sender's identity or displayed address may be forged to resemble the IT department.

- Impersonation: The attacker pretends to represent a trusted internal department.
- Urgency and fear: The message claims that immediate action is required because of a security update.
- Credential harvesting: The link may direct employees to a fake login page that captures usernames and passwords.
- Social manipulation: The attacker exploits employees' trust in IT staff and their concern about account security.

If the email is specifically targeted at selected employees or a particular organization, it may also be classified as spear phishing. However, the scenario does not provide enough information to establish that it is a targeted campaign.

## 3. How the Attack Works

The attack generally follows these steps:

1. Preparation: The attacker creates an email that resembles an official IT security notification.
2. Delivery: The email is sent to employees, requesting urgent credential verification.
3. Manipulation: The message creates a sense of urgency and encourages employees to act quickly.
4. Credential collection: The link opens a fraudulent login page that captures the information entered by employees.
5. Unauthorized access: The attacker may use stolen credentials to attempt to access organizational systems, email accounts, or sensitive data.

The exact outcome depends on the attacker's capabilities and the organization's security controls. Clicking the link alone does not necessarily mean that credentials have been stolen.

## 4. Countermeasures Employees Should Follow

1. Verify the sender's identity

- Check the complete sender address and domain.
- Look for unusual spelling, unexpected addresses, or mismatched domains.
- Do not trust an email merely because it displays the IT department's name or logo.

2. Avoid clicking suspicious links

- Do not click links in unexpected credential-verification emails.
- Navigate to the organization's official website or internal portal independently.
- If necessary, inspect the link destination using approved security procedures without opening it.

3. Confirm the request through an official channel

- Contact the IT department using a known phone number, internal help desk, or official communication channel.
- Do not use the contact details supplied only in the suspicious email.
- Confirm whether the security update and credential request are genuine.

4. Never share passwords through email

- Legitimate security procedures should not require employees to send passwords in response to an email.
- Enter credentials only into verified organizational login pages.
- Never provide passwords or one-time verification codes to an unverified requester.

5. Report the email

- Use the organization's phishing-reporting button or contact the security team.
- Preserve the suspicious message and its details according to organizational procedures.
- Avoid forwarding it to colleagues, as this may spread the attack.

6. Enable multi-factor authentication (MFA)

- MFA adds an additional verification step beyond a password.
- It can reduce the risk of unauthorized access if a password is stolen.
- Phishing-resistant MFA, such as FIDO2 security keys or passkeys, offers stronger protection against credential phishing than traditional one-time codes.

7. Provide employee awareness training

- Conduct regular phishing-awareness training.
- Teach employees to recognize suspicious links, unusual requests, urgent language, and sender impersonation.
- Use authorized phishing simulations to assess awareness and improve reporting behavior.

## 5. Organizational Security Measures

In addition to employee precautions, the organization should implement technical controls:

| Security measure | Purpose |
|---|---|
| Email filtering | Detects and blocks suspicious or malicious messages |
| SPF, DKIM, and DMARC | Helps reduce email spoofing and improve sender authentication |
| Multi-factor authentication | Adds protection beyond passwords |
| Endpoint protection | Helps detect malicious files and suspicious activity |
| Security awareness training | Improves employee ability to recognize phishing |
| Incident response procedures | Support rapid investigation and containment |
| Password reset and session revocation | Help limit damage if credentials are compromised |
| Centralized logging and monitoring | Helps detect suspicious account activity |

## 6. How These Actions Prevent Credential Theft

These countermeasures reduce the likelihood that employees will disclose their credentials to an attacker.

- Verifying sender identities helps identify impersonation.
- Avoiding suspicious links prevents employees from entering credentials on fraudulent websites.
- Confirming requests independently exposes fake security notifications.
- Reporting suspicious emails allows security teams to block similar messages before more employees are affected.
- MFA and phishing-resistant authentication reduce the risk of account compromise.
- Email filtering and employee training help prevent attacks from reaching users or succeeding.

If an employee has already entered credentials into a suspicious website, they should immediately notify the IT or security team, change the affected password through the official service, revoke active sessions where appropriate, and follow incident-response instructions.

## 7. Example

Suppose an employee receives an email stating:

Subject: Urgent Security Update – Verify Your Account Immediately

The email includes a link to a login page that looks similar to the company's official portal.

The employee should not click the link or enter their credentials. Instead, they should open the official company portal independently and contact the IT department to verify the notification. The employee should also report the email to the security team.

The security team can investigate the sender, block the malicious domain if necessary, warn other employees, and check whether any accounts have been compromised.

Conclusion: The scenario represents an impersonation-based phishing attack intended to steal employee credentials. By verifying the sender, avoiding suspicious links, reporting the email, using MFA, and following security awareness practices, employees and organizations can significantly reduce the risk of credential theft and unauthorized access.